

HiveForce Labs

THREAT ADVISORY

 **VULNERABILITY REPORT**

November 2024 Linux Patch Roundup

Date of Publication

November 15, 2024

Admiralty Code

A1

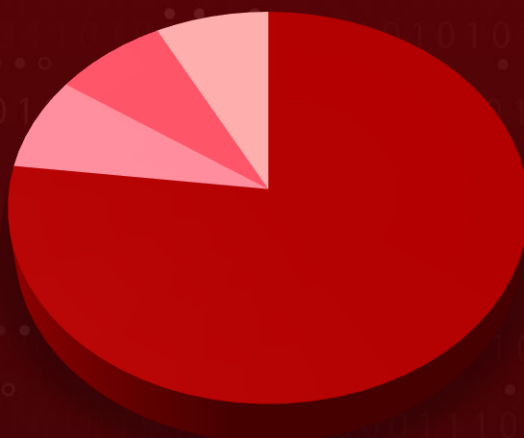
TA Number

TA2024433

Summary

In October and November, over 600 vulnerabilities in the Linux ecosystem were addressed, affecting various distributions, including Debian, Red Hat, Gentoo, OpenSUSE, and Arch Linux. These vulnerabilities span from information disclosure to privilege escalation to code execution. HiveForce labs has identified 13 severe vulnerabilities which are exploited and have high potential of successful exploitation, necessitating immediate attention. To ensure protection, it is essential to upgrade systems to the latest version with the necessary security patches and appropriate security controls.

Threat Distribution



■ Code Execution ■ Information Disclosure
■ Denial Of Service ■ Unauthorized Access

Adversary Tactics



■ Execution ■ Initial Access ■ Defense Evasion ■ Impact ■ Credential Access

CVEs

CVE	NAME	AFFECTED PRODUCT	Impact	Attack Vector
CVE-2024-9680*	Mozilla Firefox & Thunderbird Use-After-Free Vulnerability	Firefox Thunderbird	Code Execution	Phishing
CVE-2023-46604*	Apache ActiveMQ Deserialization of Untrusted Data Vulnerability	Apache ActiveMQ	Code Execution	Network
CVE-2024-47875	DOMPurify nested mXSS Vulnerability	RHEL Grafana, Openshift4, SUSE Liberty Linux 8-9	Code Execution	Remote
CVE-2024-47685	Linux Kernel Netfilter TCP Header Memory Corruption Flaw	Linux Kernel, Amazon Linux, OpenSUSE, Ubuntu	Denial Of Service	Remote
CVE-2024-47076	CUPS Insufficient IPP Attributes Validation Check Flaw	libcupsfilters (<=2.1b1)	Code Execution	Remote
CVE-2024-47176	CUPS Untrusted Printer Discovery Vulnerability	cups-browsed package (<=2.0.1)	Code Execution	Network
CVE-2024-48949	Elliptic EDDSA Missing Signature Validation Flaw	RHEL, OpenSUSE, Fedora	Unauthorized Access	Remote

* Refers to **Notable CVEs**, vulnerabilities that are either exploited in zero-day attacks, included in the CISA KEV catalog, utilized in malware operations, or targeted by threat actors in their campaigns.

CVE	NAME	AFFECTED PRODUCT	Impact	Attack Vector
CVE-2024-9954	Chromium Use After Free Flaw	Google Chrome	Code Execution	Phishing
CVE-2024-43363	Cacti Log Poisoning Remote Code Execution	Cacti (<= 1.2.27)	Code Execution	Remote
CVE-2024-47674	Linux Kernel USB Dangling PTE Vulnerability	RHEL, SUSE, Ubuntu, Debian	Code Execution	Local
CVE-2024-9392	Mozilla Firefox & Thunderbird Origin Validation Bypass	Mozilla Firefox, Thunderbird	Information Disclosure	Phishing
CVE-2024-9401	Mozilla Firefox & Thunderbird Memory Corruption Vulnerability	Mozilla Firefox, Thunderbird	Code Execution	Remote
CVE-2024-9402	Mozilla Firefox & Thunderbird Memory Corruption Vulnerability	Mozilla Firefox, Thunderbird	Code Execution	Remote

Notable CVEs

Notable CVEs include vulnerabilities exploited in zero-day attacks, listed in the CISA KEV catalog, used in malware operations, or targeted by threat actors in their campaigns.

CVE ID	CELEBRITY VULNERABILITY	AFFECTED PRODUCTS	ASSOCIATED ATTACKS/RANSOM WARE
CVE-2024-9680		Firefox, Thunderbird	-
	ZERO-DAY		ASSOCIATED ACTOR
		AFFECTED CPE	-
NAME	CISA KEV		PATCH LINKS
Mozilla Firefox & Thunderbird Use-After-Free Vulnerability		cpe:2.3:a:mozilla:firefox:*:*:*:*:*:*:* cpe:2.3:a:mozilla:firefox_esr:*:*:*:*:*:* cpe:2.3:a:mozilla:thunderbird:*:*:*:*:*:*	https://www.mozilla.org/en-US/security/advisories/mfsa2024-51/ , https://www.mozilla.org/en-US/security/advisories/mfsa2024-52/
	CWE ID	ASSOCIATED TTPs	
	CWE-416	T1189: Drive-by Compromise T1203: Exploitation for Client Execution	

CVE ID	CELEBRITY VULNERABILITY	AFFECTED PRODUCTS	ASSOCIATED ACTOR
CVE-2023-46604		Apache ActiveMQ ActiveMQ Legacy OpenWire Module	Andariel
	ZERO-DAY		
		AFFECTED CPE	ASSOCIATED ATTACKS/RANSOM WARE
NAME	CISA KEY	cpe:2.3:a:apache:activemq:*:*:*:*:*:*	RansomHub, HelloKitty, TellYouThePass, SparkRAT, Kinsing
Apache ActiveMQ Deserialization of Untrusted Data Vulnerability			
	CWE ID	ASSOCIATED TTPs	PATCH LINK
	CWE-502	T1190: Exploit Public-Facing Application T1059: Exfiltration Over C2 Channel	https://security-tracker.debian.org/tracker/source-package/activemq

Vulnerability Details

#1

In October and November, the Linux ecosystem addressed over 600 vulnerabilities across various distributions and products, covering critical issues such as information disclosure, privilege escalation, and code execution. HiveForce lab has identified 13 critical vulnerabilities that are either currently being exploited or are highly likely to be exploited in the near future.

#2

These vulnerabilities could facilitate adversary tactics such as Initial Access, Execution, Credential Access, Data Collection, Information Discovery and Defense Evasion. Notably, two of these vulnerabilities are under active exploitation, which require urgent attention and remediation.

#3

CVE-2024-9680, a user after free flaw associated with Firefox animation timeline component is reported to be exploited in wild. The second vulnerability, CVE-2023-46604, pertains to Apache ActiveMQ and was disclosed last year. It has been exploited by multiple ransomware groups, including its involvement in the Andariel campaign. The fix for this vulnerability has now been extended to Debian versions 11 (Bullseye) and 12 (Bookworm).

#4

Multiple vulnerabilities in the Common Unix Printing System (CUPS) allow attackers to force the discovery of printers and inject malicious IPP attributes, which can lead to code execution when print jobs are processed. CUPS is included by default in many Linux distributions and serves as an open-source printing system that enables users to efficiently manage and share printers across networks. It can be exploited by network user through the sending of a specially crafted UDP request to port 631.

#5

Mozilla has addressed multiple memory corruption vulnerabilities in both Firefox and Thunderbird that have the potential for code execution. Additionally, Chromium has fixed a critical use-after-free flaw, CVE-2024-9954, for which the exploit is reportedly available for purchase at \$150 on the online marketplace.

Recommendations

Proactive Strategies:



Exposure Assessment: Conduct an extensive service exposure evaluation with context of active threats to identify any publicly accessible services that may be vulnerable to exploitation. Following this assessment, it is essential to take immediate and decisive action to remediate any identified vulnerabilities by either installing necessary patches or implementing appropriate security measures. This proactive approach will help mitigate potential risks and enhance overall security posture.



User awareness is essential in defending against initial access threats, particularly in light of recent browser-related vulnerabilities that require user execution for successful exploitation. These vulnerabilities highlight the importance of educating users about phishing and the identification of malicious activities. Organizations can stay one step ahead of cyber threats by fostering a culture of security hygiene.



Restrict Service Account Access: Limiting access for service accounts on local machines can significantly reduce the potential impact of vulnerabilities such as CVE-2024-43363 and CVE-2023-46604. By restricting service accounts to only the permissions necessary for their functions, organizations can effectively minimize the risk of severe damage and decrease the likelihood of a complete system compromise.



Device Control: Implement robust USB control policies to manage and monitor device access, establishing granular whitelisting to permit only specific USB devices. This approach will effectively mitigate exploitation attempts related to CVE-2024-47674.

Reactive Strategies:



Actively monitor UDP packets for printer discovery on port 631, particularly those directed towards external networks, as they may indicate the presence of attacker-controlled print servers attempting to exploit vulnerabilities in CUPS for code execution.



Monitor the Apache ActiveMQ service socket for connections that may carry malicious XML, and validate this XML for any embedded bash or system commands. To effectively check for CVE-2024-43363, utilize a Web Application Firewall to detect requests targeting any new PHP endpoints or pages. Additionally, the creation of new PHP files within the Cacti installation directory should be flagged as a potential exploitation attempt.



Detect, Mitigate & Patch

CVE ID	TTPs	Detection	Mitigation	Patch
CVE-2024-9680	T1189: Drive-by compromise T1203: Exploitation for Client Execution	<u>DS0015: Application Log Content</u> <u>DS0009: Process Creation</u>	<u>M1050: Exploit Protection</u> <u>M1051: Update Software</u>	 <u>Firefox, Thunderbird</u>
CVE-2023-46604	T1190: Exploit Public-Facing Application T1059 : Command and Scripting Interpreter	<u>DS0015: Application Log Content</u> <u>DS0017: Command Execution</u>	<u>M1050: Exploit Protection</u>	 <u>Debian</u>
CVE-2024-47875	T1190: Exploit Public-Facing Application T1059.007 : Command and Scripting Interpreter: JavaScript	<u>DS0029: Network Traffic</u>	<u>M1050: Exploit Protection</u>	 <u>RHEL, Debian, SUSE</u>
CVE-2024-47685	T1499: Endpoint Denial of Service	<u>DS0029: Network Traffic Content</u>	<u>M1037: Filter Network Traffic</u>	 <u>Amazon Linux, SUSE</u>
CVE-2024-47076	T1659: Content Injection T1059: Command and Scripting Interpreter	<u>DS0029: Network Traffic</u> <u>DS0017: Command Execution</u>	<u>M1040: Behavior Prevention on Endpoint</u>	 <u>RHEL, Debian, SUSE, Fedora, Ubuntu</u>
CVE-2024-47176	T1133: External Remote Services T1553: Subvert Trust Controls	<u>DS0029: Network Traffic</u>	<u>M1040: Behavior Prevention on Endpoint</u>	 <u>RHEL, Debian, SUSE, Fedora, Ubuntu</u>
CVE-2024-48949	T1553: Subvert Trust Controls	<u>DS0022: File Metadata</u>	<u>M1054: Software Configuration</u>	 <u>RHEL, SUSE, Fedora</u>



CVE ID	TTPs	Detection	Mitigation	Patch
CVE-2024-9954	T1189: Drive-by compromise T1204.001: User Execution: Malicious Link	<u>DS0029: Network Traffic content</u>	<u>M1021: Restrict Web-Based Content</u>	 Link
CVE-2024-43363	T1059: Command and Scripting Interpreter T1078: Valid Accounts	<u>DS0002: User Account Authentication</u>	<u>M1026: Privileged Account Management</u>	 Link
CVE-2024-47674	T1059: Command and Scripting Interpreter	<u>DS0011: Module Load</u>	<u>M1040: Behavior Prevention on Endpoint</u>	 Debian, SUSE
CVE-2024-9392	T1185: Browser Session Hijacking T1539: Steal Web Session Cookie	<u>DS0009: Process Access</u>	<u>M1021: Restrict Web-Based Content</u>	 Firefox, Thunderbird
CVE-2024-9401	T059: Command and Scripting Interpreter	<u>DS0009: Process Creation</u>	<u>M1038: Execution Prevention</u>	 Firefox, Thunderbird
CVE-2024-9402	T059: Command and Scripting Interpreter	<u>DS0009: Process Creation</u>	<u>M1038: Execution Prevention</u>	 Firefox, Thunderbird

✂ Indicators of Compromise (IOCs)

TYPE	VALUE
URL	hxxp[:]//185[.]122[.]204[.]197/acb[.]sh, hxxp[:]//194[.]38[.]22[.]53/curl-aarch64, hxxp[:]//194[.]38[.]22[.]53/curl-amd64, hxxp[:]//194[.]38[.]22[.]53/kinsing, hxxp[:]//194[.]38[.]22[.]53/kinsing_aarch64, hxxp[:]//194[.]38[.]22[.]53/libsystem[.]so, hxxp://172.245.16[.]125/m4.png, hxxp://172.245.16[.]125/m2.png
SHA256	d8f55bbbcc20e81e46b9bf78f93b73f002c76a8fdb4dc2ae21b8609445c14f9, 0cc60a0c480e4d898fa77ab501bbd2afaf3f5fb89a2917a31e7f5fdaa6c3879c, 787e2c94e6d9ce5ec01f5cbe9ee2518431eca8523155526d6dc85934c9c5787c, c6fbd6896d162a12d9c900056781eb82f44649945808b7b009646b5397bcf6bf, C38c21120d8c17688f9aeb2af5bdafb6b75e1d2673b025b720e50232f888808a, d065d44d0412aef867f66626b5c4a3d7d0a3bdb59c61712b0c71efbf9865a7a6, 7af5c37cc308a222f910d6a7b0759837f37e3270e22ce242a8b59ed4d7ec7ceb, 5c8710638fad8eeac382b0323461892a3e1a8865da3625403769a4378622077e, dd13cf13c1fbdc76da63e76adcf36727cfe594e60af0dc823c5a509a13ae1e15, 4c9fa87e72fe59cf15131bd2f3bd7baa7a9555ceec438c1df78dd5d5b8394910, 43c8eea4bab853cda8a5ca8e9eb1a9d68ac38b32c8fee3583df33d2dfcef42ac, 6cdc10000d9291291c7ce0c63438796614bd21ec7e327c7f48c4ddd16ccf036f, c3c0cf25d682e981c7ce1cc0a00fa2b8b46cce2fa49abe38bb412da21da99cb7, 8c226e1f640b570a4a542078a7db59bb1f1a55cf143782d93514e3bd86dc07a0, 8177455ab89cc96f0c26bc42907da1a4f0b21fdc96a0cc96650843fd616551f4
Domains	mail4[.]amazuorn[.]com, hellokittycat[.]online, hellowinter[.]online
IPv4:Port	172[.]245[.]16[.]125:80, 4[.]216[.]93[.]211:5981, 27[.]102[.]128[.]152:8098
IPv4	137[.]175[.]17[.]172, 45[.]32[.]120[.]181, 172[.]245[.]16[.]125, 4[.]216[.]93[.]211, 38[.]6[.]160[.]44, 23[.]94[.]248[.]134, 23[.]225[.]116[.]3, 193[.]187[.]172[.]73
E-Mail	Service[@]hellokittycat[.]online

References

<https://lore.kernel.org/linux-cve-announce/>

<https://github.com/leonov-av/linux-patch-wednesday>

<https://www.debian.org/security/#DSAS>

<https://security.gentoo.org/glsa>

<https://lists.ubuntu.com/archives/ubuntu-security-announce/>

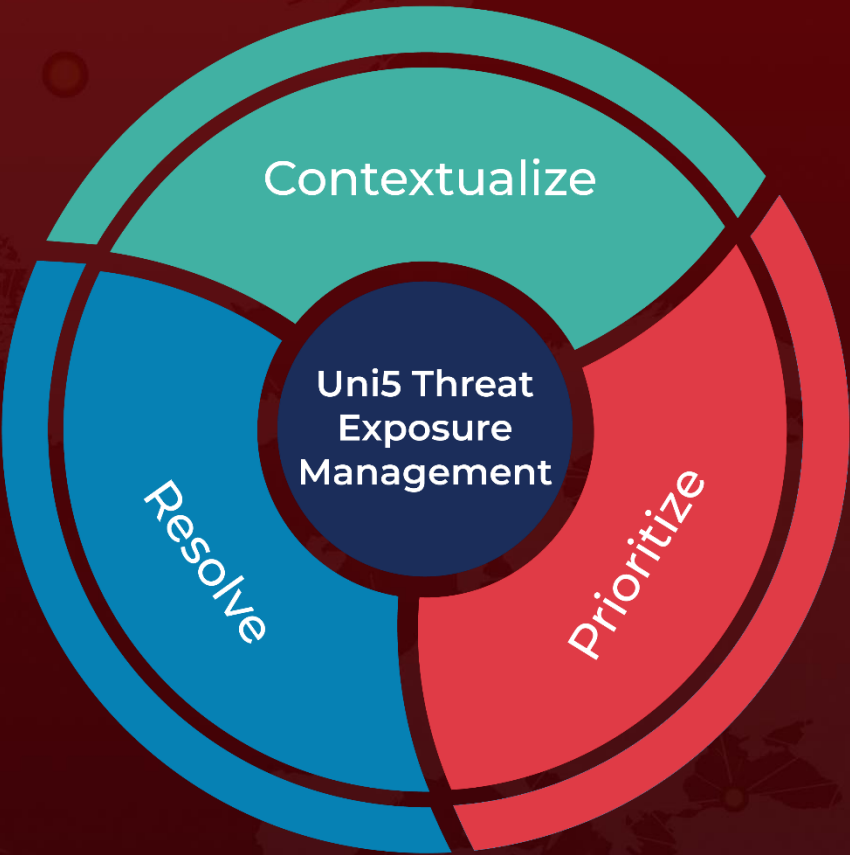
<https://hivepro.com/threat-advisory/ransomware-threats-exploit-cve-2023-46604-in-apache-activemq-servers/>

<https://hivepro.com/threat-advisory/kinsing-malware-utilizes-apache-activemq-rce-to-deploy-rootkits>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
November 15, 2024 • 6:00 AM

